IoT Security & Cybersecurity

Master 2 — Computer Science

Session 1 of 12 — Foundations: The IoT Security Landscape

Course Roadmap

This course rebuilds the discipline of IoT security around a strong cryptographic core. Sessions 1 and 3–5 and 6–7 carry most of the mathematical weight (advanced signatures, homomorphic encryption, zero-knowledge proofs, post-quantum cryptography, Cryptographic Verification); the surrounding sessions ground that theory in the IoT context and in the practice of security operations (ethical hacking, intrusion analysis, forensics, mobile security). The first session is deliberately light: it exists only to establish shared vocabulary before the course goes deep.

Session	Topic
1	Foundations: threat landscape & network security
2–5	Cryptography: symmetric/asymmetric, signatures, FHE, ZKPs, PQC
6	Identity, access management
7	anonymization, Cryptographic Verification
8	IoT data security & geolocation protection
9	Security management & ethical hacking
10	Intrusion analysis (IDS/IPS)
11	Computer forensics
12	Mobile application security

1 Introduction to IoT Security

1.1 Why IoT Changes the Security Problem

Classical computer security was built around general-purpose machines with abundant compute, memory, and a human administrator nearby. The Internet of Things inverts every one of these assumptions: billions of constrained devices, often unattended, frequently deployed in physically hostile or inaccessible locations, communicating autonomously. This shift does not introduce new threat categories so much as it removes the defenses classical security could rely on: no room for heavyweight cryptography on an 8-bit microcontroller, no administrator to patch a sensor buried in concrete, no physical perimeter around a smart meter bolted to the outside wall of a house.

Definition — Attack Surface

The attack surface of a system is the sum of all points at which an unauthorized actor could attempt to enter data into, or extract data from, that system. Formally, for a system S composed of components $\{c_1, \ldots, c_n\}$, each with an exposed interface set I_i, the attack surface is

$$\mathcal{A}(S) = \bigcup_{i=1}^{n} I_i.$$

Example — IoT attack surface growth

A single smart thermostat exposes: (1) a Wi-Fi radio, (2) a Bluetooth pairing interface, (3) a cloud API, (4) a companion mobile app, and (5) a physical reset button. Each is a member of $\mathcal{A}(S)$. Multiply this by every device in a smart building and $\mathcal{A}(S)$ grows far faster than the number of devices, because interfaces interact combinatorially.

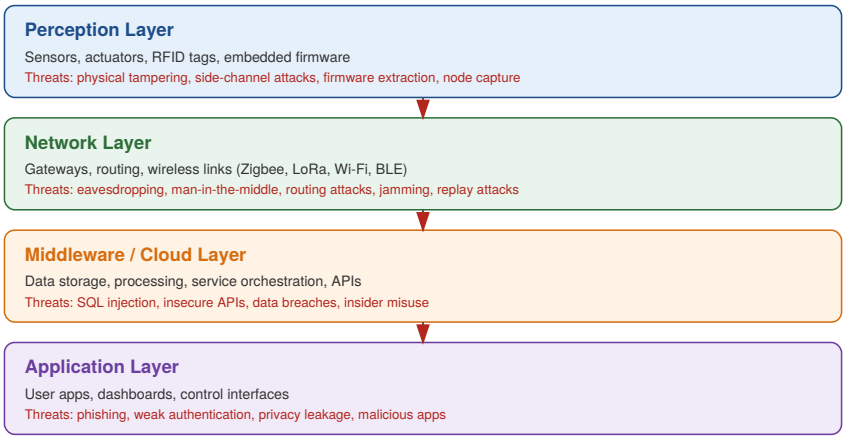


Figure 1: The four-layer IoT architecture and the threat categories characteristic of each layer.

? Think about it

Look at the four layers in Figure 1. Which layer do you think is the hardest to patch after deployment, and why?

✓ Answer

The Perception Layer. Sensors are frequently sealed, embedded in inaccessible or hostile locations, and often lack any secure remote-update mechanism — a vulnerability discovered after deployment may be unpatchable without physical device replacement.

1.2 Threats, Risks, and Vulnerabilities: Precise Definitions

These three words are used loosely in casual conversation but must be kept distinct in a security curriculum.

Definition — Vulnerability, Threat, Risk

A vulnerability is a weakness in a system that could be exploited. A threat is a potential cause of an unwanted incident, which may exploit a vulnerability. Risk is the product of the likelihood of a threat exploiting a vulnerability and the impact of the resulting incident:

$$\text{Risk} = \text{Likelihood} \times \text{Impact}.$$

Example — Applying the model to IoT

An unpatched buffer overflow in a router's firmware is a vulnerability. A remote attacker scanning the internet for that firmware version is a threat. If the router controls a hospital's medical-grade oxygen concentrators, the impact is severe, so the risk is high even if the likelihood of any single device being targeted is low.

? Think about it

Give other examples of that.

✓ Answer

Weak data encryption process. An attacker reverse-engineers the encryption mechanism. Transferring funds to another account.

1.3 The CIA Triad in an IoT Context

Security curricula traditionally organize objectives around **Confidentiality**, **Integrity**, and **Availability**. IoT stresses all three differently than traditional IT:

- **Confidentiality** is complicated by constrained devices that cannot afford expensive encryption, and by the sheer sensitivity of ambient data (e.g., health signals) that IoT sensors passively collect.
- **Integrity** matters acutely because IoT devices often act on the physical world (actuators, valves, motors); a falsified sensor reading can trigger a physically dangerous actuation.
- **Availability** is safety-critical in many deployments (industrial control, medical devices), where downtime is not merely an inconvenience but a hazard.

? Think about it

A water-treatment plant's chlorine-dosing sensor is compromised so that it always reports "normal" readings, even while the attacker manipulates the real chlorine levels. Which leg of the CIA triad is primarily violated?

✓ Answer

Integrity. Confidentiality is untouched (no secret data is disclosed), and availability is untouched (the sensor keeps reporting), but the correctness of the reported data is destroyed — and because this is a safety-critical actuator system, an integrity failure here can cause direct physical harm.

1.4 A Brief Taxonomy of IoT Threats

Threat class	Description
Physical tampering	Direct hardware access: probing, chip decapping, JTAG extraction
Firmware attacks	Reverse-engineering or replacing device firmware to insert backdoors
Network eavesdropping	Passive interception of unencrypted or weakly encrypted traffic
Denial of Service	Overwhelming constrained devices or their gateways with traffic
Botnet recruitment	Compromising devices en masse for coordinated attacks (e.g., Mirai)
Supply-chain compromise	Malicious components or firmware inserted before deployment

2 IoT Network Security

2.1 Network Security Protocols

IoT networks stack a small number of protocols to move data from constrained devices to back-end systems. The choice of protocol has direct security consequences.

Definition — Transport Layer Security (TLS) — Handshake Goal

TLS establishes a shared secret K between a client C and server S over an insecure channel, such that any passive or active adversary observing the exchange cannot recover K with better-than-negligible advantage. The handshake typically combines an asymmetric key exchange (Diffie–Hellman or its elliptic-curve variant) with certificate-based authentication of at least the server.

Example — Lightweight TLS for IoT

DTLS (Datagram TLS) adapts TLS to run over UDP, which is preferred in IoT for its lower overhead. Constrained-device profiles restrict the handshake to elliptic-curve cryptography (ECC) rather than RSA, since ECC achieves comparable security with far smaller key sizes — critical when RAM is measured in kilobytes.

Common protocols encountered in IoT deployments include MQTT (publish/subscribe messaging, often layered over TLS), CoAP (a lightweight HTTP-like protocol for constrained devices, typically secured via DTLS), and Zigbee/Z-Wave at the link layer (each with its own, historically weaker, security model).

? Think about it

MQTT is extremely popular in IoT because it is lightweight, but its default configuration often ships with no authentication and no encryption. Why might a vendor ship an insecure default despite knowing better?

✓ Answer

Time-to-market pressure and constrained-device performance budgets: enabling TLS by default increases connection setup time, RAM usage, and battery drain, all of which a vendor may perceive as more immediately costly than a security incident that might never be publicly attributed to them.

2.2 VPNs and Tunneling

Definition — Virtual Private Network

A VPN creates a logical, encrypted tunnel over a shared or public network, such that traffic between two endpoints is confidentiality- and integrity-protected as though the endpoints were on a private, isolated link. Formally, a tunneling protocol wraps each original packet P inside an encrypted envelope $E_K(P)$, decrypted only at the tunnel's far endpoint.

? Think about it

Give an example of VPN.

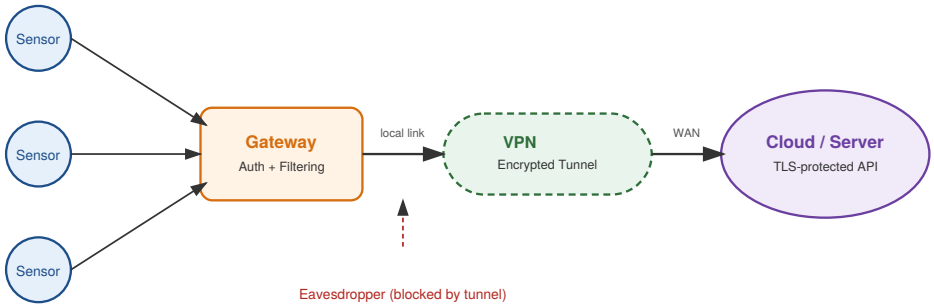


Figure 2: Sensors reach the cloud through a gateway and an encrypted VPN tunnel; an eavesdropper positioned on the WAN link cannot read tunnel contents.

✓ Answer

IPsec is the traditional enterprise VPN standard but has a large and complex codebase. WireGuard, a more recent alternative, uses a minimal, modern cryptographic suite (Curve25519, ChaCha20-Poly1305) and a codebase orders of magnitude smaller, making it easier to audit and increasingly popular for securing traffic from IoT gateways to cloud back-ends.

2.3 Sensor and Gateway Security

The gateway is the security point of most IoT deployments: it aggregates traffic from many resource-constrained sensors that cannot defend themselves, and is therefore the natural place to enforce authentication, filtering, and protocol translation.

- **Sensor hardening**: disabling unused interfaces (e.g., debug UART/JTOG ports), using secure boot to verify firmware integrity at startup, and storing keys in a hardware security element when available.
- **Gateway hardening**: enforcing mutual authentication with each sensor, applying network segmentation so a compromised sensor cannot pivot into the enterprise network, and performing protocol translation (e.g., Zigbee to MQTT) only after validating message integrity.

? Think about it

If an attacker compromises a single low-value sensor (say, a temperature probe) on a flat, unsegmented network, what is the realistic worst case?

✓ Answer

Lateral movement: because the network is flat, the compromised probe becomes a pivot point from which the attacker can reach far higher-value targets (building controllers, enterprise servers).

2.4 IoT Security Standards and Regulations

Because IoT security failures have caused real-world harm at scale, several bodies have issued baseline standards. Familiarity with these is expected of any security professional, even at a survey level.

Standard	Scope
ETSI EN 303 645	Baseline consumer IoT security: no default passwords, vulnerability disclosure policy, secure software update mechanism
NIST IR 8259	Core cybersecurity capabilities that IoT device manufacturers should build in (device identification, configuration, data protection, logical access control, telemetry)
IEC 62443	Industrial automation and control systems (ICS/SCADA) security, organized around security levels and zones/conduits
OWASP IoT Top 10	A practitioner-oriented list of the most common IoT weaknesses, mirroring the well-known OWASP Web Top 10

Example — The "no default passwords" rule

ETSI EN 303 645's single most cited provision (Provision 5.1-1) bans universal default usernames/passwords in consumer IoT devices. This single rule, had it existed a decade earlier, would have prevented the vast majority of Mirai-class botnet infections, which relied almost entirely on scanning for a short list of factory-default credentials.

? Think about it

Regulations like ETSI EN 303 645 are not criminal law — they are usually enforced through market access requirements (a device cannot be legally sold without complying). Why might this be a more effective lever than criminal prosecution of individual attackers?

✓ Answer

Market-access regulation shifts the incentive to the party with the most control over the vulnerability: the manufacturer. Prosecuting individual attackers (often anonymous, often overseas) rarely reduces the underlying vulnerability population, whereas banning insecure devices from sale directly shrinks the attack surface at its source.

2.5 A Short Case Study: Compromise Chain of a Smart Camera

To conclude this session's survey, trace a realistic compromise chain end-to-end. This pattern — weak initial foothold, lateral movement, aggregation into a botnet — recurs across nearly every major IoT incident studied later in this course.

1. **Reconnaissance**: attacker scans public IP ranges for devices exposing a known camera web-interface port.
2. **Initial access**: attacker tries a short dictionary of factory-default credentials (Perception/Application Layer vulnerability).
3. **Foothold**: attacker gains shell access via an unauthenticated firmware debug interface left enabled in production.
4. **Lateral movement**: because the camera sits on the same flat network as the household router, the attacker pivots to the router's admin interface.
5. **Aggregation**: the compromised camera is enrolled into a botnet and begins participating in distributed denial-of-service traffic — entirely invisible to the device's owner, whose only symptom might be a slightly slower home connection.

? Think about it

At which single step in this five-step chain would enforcing ETSI EN 303 645's "no default passwords" rule have broken the entire chain?

✓ Answer

Step 2 (Initial access). Every subsequent step — foothold, lateral movement, aggregation — depends causally on the attacker first gaining access, and the default credential weakness was the mechanism that made that initial access trivial. This is why regulators treat default credentials as such high-leverage low-hanging fruit.

2.6 Wireless Link-Layer Security: A Comparative View

IoT devices rarely speak Ethernet. The wireless protocol chosen at deployment time has security properties baked in at the standard level, largely outside the application developer's control.

Protocol	Typical range	Native encryption	Notable weakness
Bluetooth LE	10–100 m	AES-CCM (post-pairing)	Pairing process historically vulnerable to MITM
Zigbee	10–100 m	AES-128	Network key is often transmitted unencrypted during initial device join
LoRaWAN	2–15 km	AES-128 (two layers: network & application)	Device personalization keys, if poorly provisioned, can be extracted from firmware
Wi-Fi (IoT profile)	30–100 m	WPA2/WPA3	Many IoT devices still ship with WPA2 only, vulnerable to KRACK-style attacks

Example — The Zigbee join-key problem

When a new Zigbee device joins a network for the first time, the coordinator must transmit the network key to it. Older Zigbee stacks transmitted this key unencrypted during that single join packet, reasoning that the join window is brief. In practice, an attacker with a cheap software-defined radio can simply wait near a smart-home installation for a new bulb or sensor to be added and capture the key in that window — after which every subsequent Zigbee packet on the network is readable.

2.7 Defense in Depth

No single control surveyed above is sufficient alone; IoT security practice therefore relies on defense in depth — layering independent controls so that the failure of any one does not lead directly to compromise.

Definition — Defense in Depth

A system exhibits defense in depth if, for an attacker to achieve a given objective, they must defeat $n > 1$ independent security controls $\{c_1, \ldots, c_n\}$, where the probability of the attacker defeating all controls is strictly less than the probability of defeating any single control:

$$\Pr[\text{compromise}] = \prod_{i=1}^{n} \Pr[\text{defeat } c_i] \ll \max_i \Pr[\text{defeat } c_i].$$

Example — Layering applied to the smart camera case study

Reconsider the five-step compromise chain from Section 1.5. A defense-in-depth design would have layered: unique per-device credentials (defeats Step 2), network segmentation isolating the camera from the router's admin interface (defeats Step 4), and outbound traffic monitoring at the gateway that would flag unusual botnet-style traffic patterns (defeats Step 5) — so that even if one layer is bypassed, the attack chain still fails.

2.8 Where Cryptography Fits

Every weakness surveyed in this session — default credentials, unencrypted key transmission, weak wireless standards — ultimately reduces to a cryptographic design or implementation failure: a missing authentication step, a poorly protected key, an absent integrity check. Cyptography is the connective tissue underlying identity management, data protection, and security operations alike. Session 2 begins that treatment with the symmetric and asymmetric primitives on which every mechanism discussed today ultimately depends.

? Think about it

Looking back across this entire session, name one single design principle that, if applied consistently, would have prevented most of the incidents discussed today.

✓ Answer

Least-privilege network segmentation combined with strong, unique per-device authentication. Nearly every chain examined — the smart camera compromise, the Zigbee join-key leak, Mirai's spread — required either (a) a device authenticating with weak or shared credentials, or (b) a compromised device having unrestricted reach into the rest of the network. Removing either condition breaks most of these chains.